



**THREAT ADVISORY**

**ATTACK  
REPORT**

# MuddyWater targets Israeli organizations by exploiting unpatched log4j vulnerabilities

Date of Publication

August 30, 2022

Admiralty code

A1

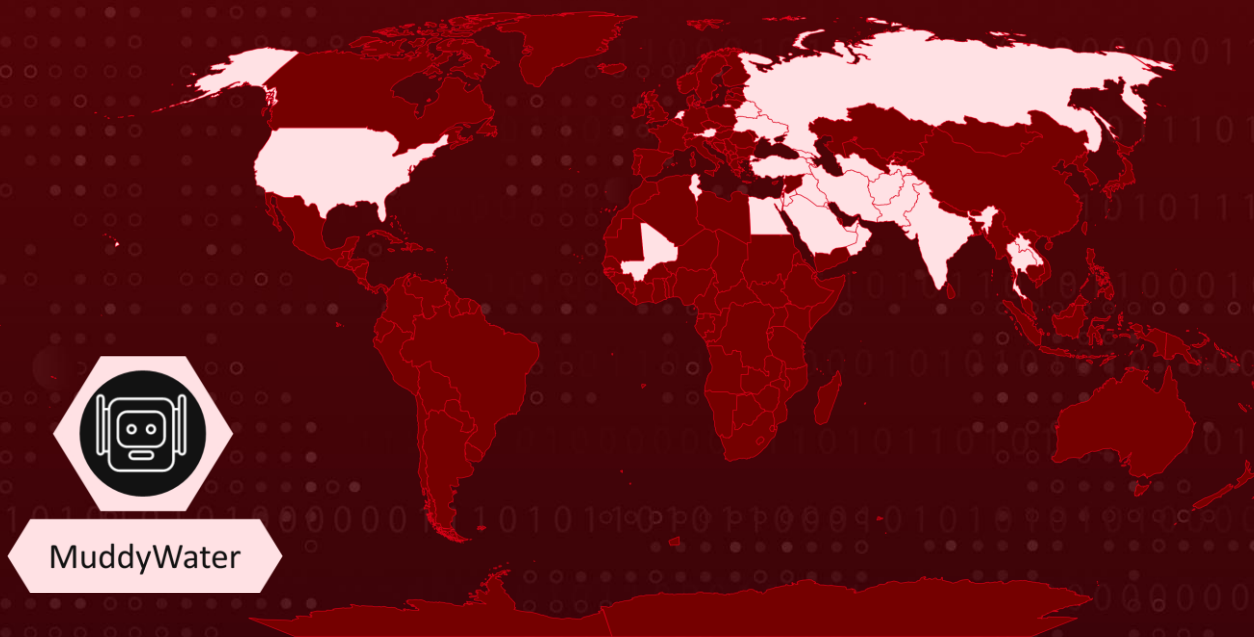
TA Number

TA2022186

# Summary

MuddyWater, an Iranian threat actor, exploits Log4j two vulnerabilities in SysAid applications to target Israeli organizations. As soon as the attacker gains access to the targeted organization, it establishes persistence, dumps credentials, and moves laterally within the organization using both custom and well-known hacking tools and operating system tools.

## Actor Map



Powered by Bing  
© Australian Bureau of Statistics, GeoNames, Microsoft, Navinfo, OpenStreetMap, TomTom, Wikipedia

| CVE            | NAME                        | PATCH |
|----------------|-----------------------------|-------|
| CVE-2021-44228 | Apache Log4j2 Vulnerability | ✓     |
| CVE-2021-45046 | Apache Log4j2 Vulnerability | ✓     |

## 🔧 Potential MITRE ATT&CK TTPs

|                                                       |                                                        |                                                      |                                              |
|-------------------------------------------------------|--------------------------------------------------------|------------------------------------------------------|----------------------------------------------|
| <b>TA0001</b><br>Initial Access                       | <b>TA0002</b><br>Execution                             | <b>TA0003</b><br>Persistence                         | <b>TA0004</b><br>Privilege Escalation        |
| <b>TA0006</b><br>Credential Access                    | <b>TA0011</b><br>Command and Control                   | <b>TA0007</b><br>Discovery                           | <b>TA0009</b><br>Collection                  |
| <b>T1133</b><br>External Remote Services              | <b>T1059</b><br>Command and Scripting Interpreter      | <b>T1059.001</b><br>PowerShell                       | <b>T1059.003</b><br>Windows Command Shell    |
| <b>T1547</b><br>Boot or Logon Autostart Execution     | <b>T1547.001</b><br>Registry Run Keys / Startup Folder | <b>T1136</b><br>Create Account                       | <b>T1136.001</b><br>Local Account            |
| <b>T1068</b><br>Exploitation for Privilege Escalation | <b>T1003</b><br>OS Credential Dumping                  | <b>T1003.001</b><br>LSASS Memory                     | <b>T1083</b><br>File and Directory Discovery |
| <b>T1082</b><br>System Information Discovery          | <b>T1016</b><br>System Network Configuration Discovery | <b>T1049</b><br>System Network Connections Discovery | <b>T1071</b><br>Application Layer Protocol   |
| <b>T1071.001</b><br>Web Protocols                     |                                                        |                                                      |                                              |

# Technical Details

**#1**

As its initial access vector, MuddyWater exploited SysAid Server vulnerable to Log4j 2 vulnerabilities. The threat actor then establishes persistence once it has gained access to the target organization by dropping a web shell, elevating privileges, and stealing credentials.

**#2**

The attackers then connect through local administrator users using the Remote Desktop Protocol (RDP). MuddyWater later dumped credentials(using Mimikatz) in SQL servers to steal other highly privileged accounts, like service accounts.

**#3**

MuddyWater then leveraged several methods to compromise other devices within the target organizations by leveraging Windows Management Instrumentation (WMI) and Remote Services (using the RemCom tool). The majority of commands were aimed at installing tools on targets or conducting reconnaissance for domain administrator accounts.

**#4**

A variety of methods were used by the attacker throughout the attack to communicate with their command-and-control (C2) server, including PowerShell, eHorus, and a tool similar to the open-source tool Ligolo.

# Actor Detail

| NAME                                                                                                         | ORIGIN                          | TARGET LOCATIONS                                                                                                                                                                                                                                                            | TARGET INDUSTRIES                                                                                                                                                                    |
|--------------------------------------------------------------------------------------------------------------|---------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| MuddyWater<br>(Seedworm, TEMP.Zagros, Static Kitten, Mercury, TA450, Cobalt Ulster, ATK 51, T-APT-14, ITG17) | Iran                            | Afghanistan, Armenia, Austria, Azerbaijan, Bahrain, Belarus, Egypt, Georgia, India, Iran, Iraq, Israel, Jordan, Malta Kuwait, Laos, Lebanon, Mali, Netherlands, Oman, Pakistan, Russia, Saudi Arabia, Tajikistan, Thailand, Tunisia, Turkmenistan Turkey, UAE, Ukraine, USA | Defense, Education, Energy, Financial, Food and Agriculture, Gaming, Government, Healthcare, High-Tech, IT, Media, NGOs, Oil and gas, Telecommunications , Transportation, Aerospace |
|                                                                                                              | MOTIVE                          |                                                                                                                                                                                                                                                                             |                                                                                                                                                                                      |
|                                                                                                              | Information theft and espionage |                                                                                                                                                                                                                                                                             |                                                                                                                                                                                      |

## Vulnerability Details

| CVE ID         | AFFECTED PRODUCTS                            | AFFECTED CPE                                      | CWE ID                                  |
|----------------|----------------------------------------------|---------------------------------------------------|-----------------------------------------|
| CVE-2021-44228 | SysAid Cloud versions before version 22.1.10 | cpe:2.3:a:sysaid:sysaid:-:*:*:*:cloud:*:*.*       | CWE-917<br>CWE-20<br>CWE-502<br>CWE-400 |
| CVE-2021-45046 | SysAid On-premises versions before 21.4.45   | cpe:2.3:a:sysaid:sysaid:-:*:*:*:on-premises:*:*.* | CWE-502                                 |

# Indicator of Compromise (IOC)

| TYPE   | VALUE                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                   |
|--------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| SHA256 | e81a8f8ad804c4d83869d7806a303ff04f31cce376c5df8aada2e9db2c1eeb98<br>416e937fb467b7092b9f038c1f1ea5ca831dd19ed478cca444a656b5d9440bb4<br>25325dc4b8dcf3711e628d08854e97c49cfb904c08f6129ed1d432c6bfff576b<br>3c2fe308c0a563e06263bbacf793bbe9b2259d795fcc36b953793a7e499e7f71<br>3137413d086b188cd25ad5c6906fbb396554f36b41d5cff5a2176c28dd29fb0a<br>87f317bbba0f50d033543e6ebab31665a74c206780798cef277781dfd4c3f2f<br>e4ca146095414dbe44d9ba2d702fd30d27214af5a0378351109d5f91bb69cdb6<br>d2e2a0033157ff02d3668ef5cc56cb68c5540b97a359818c67bd3e37691b38c6<br>3ca1778cd4c215f0f3bcfdd91186da116495f2d9c30ec22078eb4061ae4b5b1b<br>bbfee9ef90814bf41e499d9608647a29d7451183e7fe25f472c56db9133f7e40<br>b8206d45050df5f886afefa25f384bd517d5869ca37e08eba3500cda03bddfef |
| IPv4   | 91[.]121[.]240[.]104<br>164[.]132[.]237[.]64                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
| Domain | hxxp://sygateway[.]com                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |

## Patch Links

<https://www.sysaid.com/security-compliance/important-update-regarding-apache-log4j>

<https://www.sysaid.com/product/on-premises/latest-release>

## References

<https://www.microsoft.com/security/blog/2022/08/25/mercury-leveraging-log4j-2-vulnerabilities-in-unpatched-systems-to-target-israeli-organizations/>

# What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

**August 30, 2022 • 1:00 AM**

© 2022 All Rights are Reserved by HivePro



More at [www.hivepro.com](https://www.hivepro.com)